

SOLARWINDS CASE STUDY

Τμήμα Πληροφορικής
Εαρινό Εξάμηνο 2025-26

Υλοποιήθηκε από:
Κυνηγοπούλου Αναστασία

Διδάσκοντας:
Γκριτζαλης Δημήτρης



ΟΠΑ
ΑΥΕΒ

ΠΙΝΑΚΑΣ ΠΕΡΙΕΧΟΜΕΝΩΝ

ΠΕΡΙΛΗΨΗ	3
Μέρος Α: Επισκόπηση Supply Chain Attack κατά της SolarWinds:Ιστορικό, Εμπλεκόμενοι και Επιπτώσεις.....	4
1. Εισαγωγή	4
2. Χρονολόγιο και Εξέλιξη της Επίθεσης	4
3. Επιπτώσεις	5
Μέρος Β: Λεπτομερής Τεχνική Ανάλυση της Επίθεσης.....	6
1. Επισκόπηση	6
2. Τεχνική Ανάλυση ανά Στάδιο	6
4.Απεικόνιση των σταδίων της επίθεσης.....	10
.....	10
5. Αναλυτική Αντιστοίχιση MITRE ATT&CK	11
Μέρος Γ: Ανάλυση Αστοχιών Ανίχνευσης, Προτεινόμενα Μέτρα Πρόληψης και Διδάγματα για την Ασφάλεια Εφοδιαστικής Αλυσίδας	12
1. Λόγοι μη Έγκαιρου Εντοπισμού της Επίθεσης	12
2. Το Ζήτημα του Κωδικού "solarwinds123"	12
3. Προτεινόμενα Μέτρα Ασφάλειας και Συμπεράσματα	13
ΒΙΒΛΙΟΓΡΑΦΙΑ.....	14

ΠΕΡΙΛΗΨΗ

Η παρούσα εργασία αναλύει την κυβερνοεπίθεση κατά της SolarWinds που αποκαλύφθηκε τον Δεκέμβριο του 2020, μια από τις πλέον εξελιγμένες επιθέσεις εφοδιαστικής αλυσίδας (supply chain attacks) στην ιστορία της κυβερνοασφάλειας. Οι δράστες κατάφεραν να ενσωματώσουν τον κακόβουλο κώδικα SUNBURST σε νόμιμα υπογεγραμμένες ενημερώσεις της πλατφόρμας Orion, θέτοντας σε κίνδυνο περίπου 18.000 οργανισμούς, μεταξύ των οποίων κρίσιμοι φορείς της αμερικανικής ομοσπονδιακής κυβέρνησης και εταιρείες παγκόσμιας εμβέλειας.

Στο Μέρος Α παρουσιάζεται η επισκόπηση του περιστατικού: το ιστορικό της SolarWinds, η χρονολογική εξέλιξη της επίθεσης από τον Σεπτέμβριο του 2019 έως την αποκάλυψή της από τη FireEye, οι εμπλεκόμενοι οργανισμοί και οι εκτεταμένες επιπτώσεις σε επιχειρησιακό, οικονομικό και στρατηγικό επίπεδο.

Στο Μέρος Β πραγματοποιείται λεπτομερής τεχνική ανάλυση των έξι σταδίων της επίθεσης, από την αρχική παραβίαση του build environment έως την εξαγωγή ευαίσθητων δεδομένων, με πλήρη αντιστοίχιση στο πλαίσιο MITRE ATT&CK. Αναλύονται οι τεχνικές αποφυγής ανίχνευσης, η C2 επικοινωνία μέσω DNS και HTTP, η πλευρική κίνηση μέσω TEARDROP/RAINDROP και Golden SAML, καθώς και το ξεχωριστό κακόβουλο λογισμικό SUPERNova.

Στο Μέρος Γ εξετάζονται οι λόγοι που η επίθεση παρέμεινε αόρατη για δεκατέσσερις μήνες, το ζήτημα του κωδικού "solarwinds123" ως ένδειξη ευρύτερης δυσλειτουργίας στην κουλτούρα ασφαλείας, και τα προτεινόμενα μέτρα πρόληψης. Τα συμπεράσματα αναδεικνύουν ότι η απόδοση ευθυνών παραμένει αβέβαιη, ότι η εταιρεία χειρίστηκε προβληματικά τη μετα-περιστατικό επικοινωνία, και ότι το περιστατικό οδήγησε σε ρυθμιστικές αλλαγές όπως το Executive Order 14028.

Το κεντρικό δίδαγμα της εργασίας είναι ότι οι επιθέσεις εφοδιαστικής αλυσίδας αποτελούν μια εγγενή ευπάθεια των σύγχρονων ψηφιακών οικοσυστημάτων. Η παραβίαση ενός μόνο αξιόπιστου παρόχου αρκεί για να εκθέσει χιλιάδες οργανισμούς, ανεξαρτήτως του επιπέδου ασφαλείας που εφαρμόζουν οι ίδιοι. Η προστασία απαιτεί θεμελιώδη αλλαγή νοοτροπίας: από την τυφλή εμπιστοσύνη στους παρόχους, στη συνεχή επαλήθευση, τη διαφάνεια και τη συλλογική ευθύνη.

Μέρος Α:

Επισκόπηση Supply Chain Attack κατά της SolarWinds: Ιστορικό, Εμπλεκόμενοι και Επιπτώσεις

1. Εισαγωγή

Μια επίθεση εφοδιαστικής αλυσίδας (supply chain attack) αποτελεί έναν τύπο κυβερνοεπίθεσης που στοχεύει έναν έμπιστο τρίτο πάροχο (third-party vendor), ο οποίος παρέχει υπηρεσίες ή λογισμικό σε έναν οργανισμό ή μια επιχείρηση. Οι επιθέσεις αυτού του τύπου παρουσιάζουν αύξηση της τάξεως του 430% κατά τα τελευταία έτη, καθώς, ενώ οι επιχειρήσεις βελτιώνουν συνεχώς τη θωράκιση (hardening) των περιβαλλόντων τους, οι κακόβουλοι δράστες (threat actors) έχουν στραφεί προς πιο ευάλωτους στόχους, όπως εταιρείες μικρότερης κλίμακας, αναπτύσσοντας παράλληλα εξελιγμένες μεθόδους ώστε να καθιστούν τις ενέργειές τους δυσδιάκριτες και να μεγιστοποιούν τις πιθανότητες παραβίασης (compromise) των επιθυμητών στόχων.

Υπό αυτό το πρίσμα, η κυβερνοεπίθεση κατά της SolarWinds Corporation, μιας αμερικανικής εταιρείας με έδρα το Austin του Τέξας, η οποία αναπτύσσει λογισμικό διαχείρισης πληροφοριακών συστημάτων (IT management software) για οργανισμούς παγκοσμίως, δεν αποτελεί μεμονωμένο περιστατικό, αλλά συνιστά ένα εξαιρετικά χαρακτηριστικό παράδειγμα επίθεσης εφοδιαστικής αλυσίδας. Η πλατφόρμα Orion, το κορυφαίο προϊόν της εταιρείας, προσφέρει δυνατότητες παρακολούθησης δικτύων (network monitoring) και αξιοποιείται από περίπου 33.000 πελάτες, μεταξύ των οποίων κυβερνητικές υπηρεσίες και εταιρείες της λίστας Fortune 500. Δεδομένου ότι το λογισμικό λειτουργεί κατά κανόνα με αυξημένα δικαιώματα πρόσβασης (elevated privileges), τόσο για την παρακολούθηση της δικτυακής κίνησης (network traffic) όσο και για την πρόσβαση σε εξυπηρετητές, δικτυακές συσκευές και εφαρμογές σε ολόκληρο το εύρος ενός οργανισμού, η ευρεία διείσδυσή του στην αγορά το κατέστησε ιδανικό φορέα επίθεσης.

Στη συγκεκριμένη περίπτωση, οι κακόβουλοι δράστες παραβίασαν το περιβάλλον ανάπτυξης λογισμικού (build environment) της SolarWinds και ενσωμάτωσαν κακόβουλο κώδικα σε ενημερώσεις της πλατφόρμας Orion, τις οποίες η εταιρεία διένειμε στη συνέχεια στους πελάτες της. Η επίθεση αποδόθηκε, με υψηλό βαθμό εμπιστοσύνης, στην ομάδα APT29 (Advanced Persistent Threat group 29), γνωστή επίσης ως Cozy Bear και SolarStorm, η οποία συνδέεται στενά με την Υπηρεσία Εξωτερικών Πληροφοριών της Ρωσίας (SVR).

2. Χρονολόγιο και Εξέλιξη της Επίθεσης

Η επίθεση ακολούθησε μια μεθοδική εξέλιξη που εκτάθηκε σε χρονικό διάστημα άνω του ενός έτους πριν τον τελικό εντοπισμό της, αποκαλύπτοντας τόσο τον

υψηλό βαθμό σχεδιασμού όσο και την αξιοσημείωτη επιχειρησιακή πειθαρχία των δραστών.

Η αρχική παραβίαση (initial compromise) τοποθετείται τον Σεπτέμβριο του 2019, όταν οι δράστες απέκτησαν πρόσβαση στο εσωτερικό περιβάλλον ανάπτυξης λογισμικού της SolarWinds. Τον Οκτώβριο του ίδιου έτους, πραγματοποίησαν μια πρώτη δοκιμαστική έγχυση αβλαβούς κώδικα, επαληθεύοντας τη δυνατότητα τροποποίησης του πηγαίου χωρίς ανίχνευση. Τον Φεβρουάριο του 2020, μέσω της παραβίασης του build environment, ο κακόβουλος κώδικας SUNBURST ενσωματώθηκε εντός της πλατφόρμας Orion, σχεδιασμένος με ιδιαίτερη επιμέλεια ώστε να αποφεύγει τον εντοπισμό.

Από τον Μάρτιο έως τον Ιούνιο του 2020, η SolarWinds διένειμε εν αγνοία της τις παραβιασμένες ενημερώσεις στους πελάτες της. Οι ενημερώσεις ήταν ψηφιακά υπογεγραμμένες με τα νόμιμα πιστοποιητικά υπογραφής κώδικα (code-signing certificates) της εταιρείας, καθιστώντας τις φαινομενικά αυθεντικές. Περίπου 18.000 οργανισμοί εγκατέστησαν τις κακόβουλες ενημερώσεις.

Ωστόσο, οι δράστες δεν επεδίωξαν τη μαζική εκμετάλλευση του συνόλου των θιγόμενων οργανισμών. Κατά την περίοδο ενεργής εκμετάλλευσης (Μάρτιος–Δεκέμβριος 2020), επέλεξαν στοχευμένα περίπου 100 οργανισμούς για βαθύτερη διείσδυση. Μεταξύ των στόχων υψηλής αξίας περιλαμβάνονταν κρίσιμοι φορείς της αμερικανικής ομοσπονδιακής κυβέρνησης, συμπεριλαμβανομένων του Υπουργείου Οικονομικών, του Υπουργείου Εμπορίου, του Υπουργείου Εσωτερικής Ασφάλειας, του Υπουργείου Εξωτερικών, τμημάτων του Πενταγώνου και των Εθνικών Ινστιτούτων Υγείας, καθώς και εταιρείες όπως η Microsoft, η Intel, η Cisco και η Deloitte. Για τα θύματα αυτά, οι δράστες εγκατέστησαν πρόσθετο κακόβουλο λογισμικό και αξιοποίησαν νόμιμα διαπιστευτήρια για πλευρική κίνηση (lateral movement) εντός των δικτύων, πρόσβαση σε συστήματα ηλεκτρονικού ταχυδρομείου και εξαγωγή ευαίσθητων δεδομένων (data exfiltration).

Η επίθεση παρέμεινε αόρατη έως τον Δεκέμβριο του 2020, όταν εντοπίστηκε από την εταιρεία κυβερνοασφάλειας FireEye (πλέον Mandiant), κατά τη διερεύνηση επίθεσης που είχε υποστεί η ίδια στα συστήματά της. Η FireEye χαρακτήρισε την επίθεση ως ένα από τα υψηλότερα επίπεδα operational security που έχει καταγράψει, με εστίαση στην αποφυγή εντοπισμού και στην αξιοποίηση της εγγενούς εμπιστοσύνης (inherent trust).

3. Επιπτώσεις

Η επίθεση αποτέλεσε κρίσιμο περιστατικό κυβερνοασφάλειας με εκτεταμένο αντίκτυπο σε οργανισμούς παγκοσμίως. Επηρέασε το 85% των εξεταζόμενων εταιρειών, με το 31% να υφίσταται σημαντικές επιπτώσεις. Το μέσο οικονομικό κόστος ανήλθε στο 11% ($\approx$ \$12,3 εκατομμύρια κατά μέσο όρο) των ετήσιων εσόδων, αναδεικνύοντας υψηλό επιχειρησιακό και οικονομικό ρίσκο. Παράλληλα, σε στρατηγικό επίπεδο, το 91% των οργανισμών επαναξιολόγησε την ασφάλεια της εφοδιαστικής αλυσίδας, ενώ το 42% υλοποίησε άμεσες

βελτιώσεις. Τέλος, ενισχύθηκε η ανταλλαγή πληροφοριών μεταξύ οργανισμών, αναδεικνύοντας ότι η ασφάλεια της εφοδιαστικής αλυσίδας αποτελεί πλέον ζήτημα συλλογικής ευθύνης και όχι αποκλειστικά εσωτερική υπόθεση κάθε οργανισμού.

Μέρος Β:

Λεπτομερής Τεχνική Ανάλυση της Επίθεσης

1. Επισκόπηση

Η επίθεση κατά της SolarWinds βασίστηκε σε μια εξαιρετικά εξελιγμένη τεχνική παραβίασης εφοδιαστικής αλυσίδας (supply chain compromise), κατά την οποία κακόβουλος κώδικας ενσωματώθηκε σε ψηφιακά υπογεγραμμένες ενημερώσεις λογισμικού, επιτρέποντας στους επιτιθέμενους να αποκτήσουν αρχική πρόσβαση σε πλήθος οργανισμών. Μέσω τεχνικών απόκρυψης, όπως η καθυστερημένη ενεργοποίηση και η μίμηση νόμιμης δικτυακής δραστηριότητας, το κακόβουλο λογισμικό απέφυγε τον εντοπισμό για χρονικό διάστημα που εκτείνεται σε αρκετούς μήνες. Στη συνέχεια, αξιοποιήθηκαν μηχανισμοί command-and-control (C2) μέσω HTTP και DNS, καθώς και τεχνικές παραποίησης SAML tokens, δημιουργώντας μια πολυεπίπεδη αλυσίδα εκμετάλλευσης (multi-vector exploit chain) που αποδεικνύει τον εξαιρετικά υψηλό βαθμό τεχνικής κατάρτισης και επιχειρησιακής πειθαρχίας των δραστών. Η ανάλυση που ακολουθεί εξετάζει διεξοδικά κάθε στάδιο της επίθεσης, αντιστοιχίζοντάς το με το πλαίσιο MITRE ATT&CK.

2. Τεχνική Ανάλυση ανά Στάδιο

Στάδιο 1: Initial Access: Supply Chain Compromise

Η αρχική πρόσβαση επιτεύχθηκε μέσω παραβίασης της διαδικασίας κατασκευής λογισμικού (build process) της SolarWinds. Κρίσιμη δομική αδυναμία αποτέλεσε το γεγονός ότι η αυθεντικοποίηση του IT network και του development network της εταιρείας δεν ήταν διαχωρισμένη, χρησιμοποιώντας ενιαία one-way authentication και για τα δύο δίκτυα, παράβαση που θα είχε εντοπιστεί εάν εφαρμόζονταν πρότυπα όπως τα NERC CIP-005-6, τα οποία απαιτούν ρητό διαχωρισμό μεταξύ IT και development περιβαλλόντων.

Οι επιτιθέμενοι, αφού απέκτησαν πρόσβαση στο εσωτερικό περιβάλλον ανάπτυξης τον Σεπτέμβριο του 2019, κατάφεραν μέσω ξεχωριστής επίθεσης στο build environment να ενσωματώσουν τον κακόβουλο κώδικα SUNBURST στη διαδικασία compilation του Orion. Η έγχυση πραγματοποιούνταν κατά το build, τροποποιώντας τον πηγαίο κώδικα πριν προλάβει ο compiler να τον διαβάσει, χωρίς να αφήνει ίχνη στο source code repository. Αξίζει να σημειωθεί ότι τον Οκτώβριο του 2019 οι δράστες πραγματοποίησαν πρώτα μια δοκιμαστική έγχυση αβλαβούς κώδικα, αξιολογώντας τη δυνατότητα τροποποίησης χωρίς ανίχνευση πριν προβούν σε κακόβουλη δράση. Μέσω ενός

μόνο παραβιασμένου παρόχου, οι δράστες απέκτησαν δυνητική πρόσβαση σε χιλιάδες οργανισμούς. Σε ερευνητικό επίπεδο, η Kaspersky ανακάλυψε ομοιότητες κώδικα μεταξύ του SUNBURST και του Kazuar backdoor. Η τεχνική αντιστοιχεί στο MITRE ATT&CK T1195.002 (Compromise Software Supply Chain).

Στάδιο 2 : Execution: Code Injection μέσω Signed DLL

Ο κακόβουλος κώδικας SUNBURST ενσωματώθηκε στο αρχείο SolarWinds.Orion.Core.BusinessLayer.dll, ένα νόμιμο και ψηφιακά υπογεγραμμένο component της πλατφόρμας Orion. Ο κώδικας ήταν κρυμμένος σε νόμιμα namespaces και classes του Orion framework, αξιοποιώντας ψευδή ονόματα μεταβλητών (fake variable names) ώστε να μην διακρίνεται κατά το code review. Η κλάση SolarWinds.Orion.Core.BusinessLayer.OrionImprovementBusinessLayer υλοποιούσε τον HTTP-based backdoor, ενώ η κλήση του κακόβουλου κώδικα γινόταν μέσω μιας λογικά άσχετης ρουτίνας (RefreshInternal), γεγονός που δυσχέρανε περαιτέρω τον εντοπισμό.

Μετά την εγκατάσταση, το κακόβουλο DLL φορτωνόταν από το νόμιμο εκτελέσιμο SolarWinds.BusinessLayerHost.exe, εκτελώντας τον backdoor ως trusted process. Κατά την αρχικοποίησή του, ο SUNBURST επαλήθευε ότι η ονομασία της διεργασίας αντιστοιχεί στο αναμενόμενο hash, χρησιμοποιώντας αλγόριθμο FNV-1A 64-bit με πρόσθετη XOR. Τα συστήματα ασφαλείας αντιμετώπιζαν τον κακόβουλο κώδικα ως νόμιμη δραστηριότητα, εξαλείφοντας κάθε πιθανότητα ανίχνευσης μέσω παραδοσιακών μεθόδων. Οι τεχνικές αυτές αντιστοιχούν στα MITRE ATT&CK T1553.002 (Code Signing) και T1059 (Command and Scripting Interpreter).

Στάδιο 3: Defense Evasion

Οι τεχνικές αποφυγής ανίχνευσης αποτέλεσαν τον πυρήνα της επιτυχίας της επίθεσης. Ο SUNBURST παρέμενε αδρανής για διάστημα 12 έως 14 ημερών μετά την εγκατάσταση, ελέγχοντας ότι ο χρόνος εγγραφής του αρχείου (filesystem write time) είναι τουλάχιστον 12-14 ημέρες παλαιότερος. Μεταμφίεζε τη δικτυακή κίνηση ως νόμιμο πρωτόκολλο Orion Improvement Program (OIP) και αποθήκευε αποτελέσματα αναγνώρισης σε νόμιμα αρχεία ρυθμίσεων plugin, εναρμονιζόμενος πλήρως με την κανονική δραστηριότητα του συστήματος.

Ο κώδικας χρησιμοποιούσε obfuscated blocklists για τον εντοπισμό forensic εργαλείων, antivirus και υπηρεσιών ασφαλείας που εκτελούνταν ως processes, services και drivers. Εφόσον ανιχνεύονταν blocklisted services, ο SUNBURST τα απενεργοποιούσε μέσω τροποποίησης του registry (τιμή Start = 4), ενώ εάν ανιχνεύονταν blocklisted drivers μέσω WMI query, η εκτέλεση αναστελλόταν και επιχειρούνταν εκ νέου αργότερα. Παράλληλα, οι επιτιθέμενοι αξιοποιούσαν αποκλειστικά νόμιμα εργαλεία συστήματος (PowerShell, CMD) και νόμιμα credentials, ενεργώντας σαν διαχειριστές δικτύου. Εφάρμοζαν τεχνικές διαγραφής αρχείων καταγραφής (log deletion) και συστηματικής αφαίρεσης backdoors μετά την εξασφάλιση νόμιμης πρόσβασης. Ο τρόπος επηρεασμού

ήταν η μακροχρόνια παραμονή χωρίς εντοπισμό για περίπου επτά μήνες. Οι τεχνικές αντιστοιχούν στα MITRE ATT&CK T1027 (Obfuscated Files or Information), T1518.001 (Security Software Discovery) και T1070 (Indicator Removal).

Στάδιο 4 : Command and Control (C2)

Η επικοινωνία με τους εξυπηρετητές εντολών και ελέγχου πραγματοποιούνταν μέσω δύο καναλιών. Πρωτίστως, ο SUNBURST χρησιμοποιούσε αλγόριθμο δημιουργίας ονομάτων τομέα (Domain Generation Algorithm γνωστός και ως DGA) για την κατασκευή subdomains του ansvmcloud[.]com. Τα subdomains κωδικοποιούσαν το domain name του θύματος μέσω αντιστρέψιμης κωδικοποίησης σε συνδυασμό με ένα μοναδικό userID (βασισμένο σε MD5 hash από MAC address, domain name και MachineGuid), επιτρέποντας στους δράστες να στοχεύουν επιλεκτικά συγκεκριμένα θύματα. Η απόκριση του DNS καθόριζε τη συμπεριφορά του malware: CNAME records υποδείκνυαν τον C2 server, ενώ A records εντός συγκεκριμένων IP ranges (π.χ. 10.0.0.0/8, 172.16.0.0/12) λειτουργούσαν ως killswitch, τερματίζοντας τη λειτουργία του. Η FireEye και η Microsoft συνεργάστηκαν με τη GoDaddy για να αναλάβουν τον έλεγχο του κακόβουλου domain και να τροποποιήσουν απαντήσεις του DNS, αδρανοποιώντας τον SUNBURST.

Παράλληλα, η HTTP C2 επικοινωνία χρησιμοποιούσε JSON payloads με schema μιμούμενο νόμιμη δραστηριότητα SolarWinds (EventType: "Orion", EventName: "EventManager"). Οι GET/HEAD μέθοδοι χρησιμοποιούνταν για λήψη εντολών, ενώ PUT (payload < 10.000 bytes) και POST (payload > 10.000 bytes) για αποστολή δεδομένων. Οι εντολές C2 κρύβονταν σε HTTP responses μέσω στεγανογραφίας (steganography), διασκορπισμένες σε GUID και HEX strings που έμοιαζαν με αβλαβές XML σχετικό με .NET assemblies. Τα δεδομένα αποκωδικοποιούνταν μέσω single-byte XOR και αποσυμπιέζονταν μέσω DEFLATE. Ο SUNBURST εφαρμόζεε τυχαίες καθυστερήσεις μεταξύ DNS requests (από 1-3 λεπτά έως 9 ώρες σε περίπτωση σφάλματος), ενώ η ελάχιστη καθυστέρηση μεταξύ HTTP κλήσεων ήταν ένα λεπτό. Οι τεχνικές αντιστοιχούν στα MITRE ATT&CK T1071.001 (Web Protocols), T1071.004 (Application Layer Protocol: DNS), T1568.002 (Domain Generation Algorithms) και T1132.001 (Standard Encoding).

Στάδιο 5: Lateral Movement και Credential Access

Μετά την εξασφάλιση αρχικής πρόσβασης, οι δράστες προχώρησαν σε πλευρική κίνηση εντός των δικτύων των στόχων υψηλής αξίας, αξιοποιώντας πολλαπλούς vectors. Χρησιμοποιούσαν πάντοτε διαφορετικά credentials για lateral movement σε σχέση με αυτά που αξιοποιούνταν για remote access, δυσχεραίνοντας τη συσχέτιση δραστηριοτήτων. Εγκατέστησαν επιπλέον το TEARDROP, ένα memory-only dropper που εκτελούσε κώδικα αποκλειστικά στη μνήμη χωρίς παρουσία στον δίσκο διαβάζοντας από αρχείο με ψεύτικη κεφαλίδα JPG ("gracious_truth.jpg") και χρησιμοποιώντας rolling XOR αλγόριθμο αποκωδικοποίησης καθώς και τον RAINDROP, ο οποίος ήταν ειδικά σχεδιασμένος για post-compromise lateral movement, παραδίδοντας Cobalt

Strike BEACON payload. Το BEACON υποστηρίζει lateral movement μέσω πολλαπλών πρωτοκόλλων και πλήθος C2 λειτουργιών. Επιπλέον, οι δράστες εφάρμοσαν τεχνικές temporary file replacement (αντικατάσταση νόμιμου utility, εκτέλεση payload, επαναφορά αρχικού) και προσωρινής τροποποίησης scheduled tasks.

Σε ορισμένες περιπτώσεις, οι δράστες κατάφεραν να κλέψουν το ADFS token-signing certificate για τη δημιουργία πλαστών SAML tokens, μια τεχνική γνωστή ως "Golden SAML", αποκτώντας πρόσβαση σε Azure AD και περιβάλλοντα Microsoft 365. Η αλυσίδα ολοκληρωνόταν με τροποποίηση Federation Trust για μακροχρόνια πρόσβαση, αλλαγή credentials και OAuth applications, και τελικώς εξαγωγή δεδομένων ηλεκτρονικού ταχυδρομείου. Οι τεχνικές αυτές αντιστοιχούν στα MITRE ATT&CK T1021 (Remote Services), T1078 (Valid Accounts), T1053 (Scheduled Task/Job), T1105 (Ingress Tool Transfer) και T1550 (Use Alternate Authentication Material).

Στάδιο 6: Collection και Exfiltration

Στο τελικό στάδιο, οι δράστες συνέλεξαν και εξήγαγαν ευαίσθητα δεδομένα από τους περίπου 100 οργανισμούς που είχαν επιλεγεί για βαθύτερη διείσδυση. Η εξαγωγή πραγματοποιήθηκε μέσω του υφιστάμενου C2 καναλιού. Μεταξύ των δεδομένων που εξήχθησαν περιλαμβάνονται χιλιάδες emails από το Υπουργείο Δικαιοσύνης, το Υπουργείο Οικονομικών και Εσωτερικής Ασφάλειας των ΗΠΑ καθώς και source code και certificates προγραμμάτων της Microsoft. Ο CEO της FireEye Kevin Mandia κατέθεσε ενώπιον του Κογκρέσου ότι ίσως είναι αδύνατο να προσδιοριστεί πλήρως η έκταση της ζημιάς. Οι τεχνικές αντιστοιχούν στα MITRE ATT&CK T1041 (Exfiltration Over C2 Channel) και T1114 (Email Collection).

4.Απεικόνιση των σταδίων της επίθεσης

(AI generated με την χρήση chatgpt)



5. Αναλυτική Αντιστοίχιση MITRE ATT&CK

MITRE ATT&CK Tactic	Technique ID	Technique Name	Χρήση στην Επίθεση
Initial Access	T1195.002	Supply Chain Compromise	Παραβίαση build process, trojanized Orion updates
Execution	T1059	Command and Scripting Interpreter	PowerShell, CMD εκτέλεση εντολών
Persistence	T1553.002	Code Signing	Signed DLL με νόμιμα certificates
Defense Evasion	T1027	Obfuscated Files or Information	FNV-1A hashed blocklists
Defense Evasion	T1518.001	Security Software Discovery	Εντοπισμός AV/forensic tools
Defense Evasion	T1070	Indicator Removal	Log deletion, backdoor removal
Command & Control	T1071.001	Web Protocols	HTTP C2 με JSON/OIP mimicry
Command & Control	T1071.004	DNS	DGA subdomains avsvmcloud[.]com
Command & Control	T1568.002	Domain Generation Algorithms	Encoded victim domain σε subdomains
Command & Control	T1132.001	Standard Encoding	XOR/DEFLATE κωδικοποίηση
Credential Access	T1550	Use Alternate Authentication Material	Golden SAML, forged SAML tokens
Lateral Movement	T1021	Remote Services	Πρόσβαση σε εσωτερικά συστήματα
Lateral Movement	T1078	Valid Accounts	Διαφορετικά credentials ανά στάδιο
Collection	T1114	Email Collection	Πρόσβαση σε M365 email
Exfiltration	T1041	Exfiltration Over C2 Channel	DEFLATE/XOR μέσω HTTP C2

Μέρος Γ: Ανάλυση Αστοχιών Ανίχνευσης, Προτεινόμενα Μέτρα Πρόληψης και Διδάγματα για την Ασφάλεια Εφοδιαστικής Αλυσίδας

1. Λόγοι μη Έγκαιρου Εντοπισμού της Επίθεσης

Η επίθεση κατά της SolarWinds παρέμεινε αόρατη για χρονικό διάστημα άνω των δεκατεσσάρων μηνών, γεγονός που οφείλεται σε έναν συνδυασμό εξελιγμένων τεχνικών αποφυγής ανίχνευσης και δομικών αδυναμιών στη στάση ασφαλείας (security posture) τόσο της εταιρείας όσο και των πελατών της.

Όπως αναφέρθηκε και προηγουμένως, ο θεμελιώδης λόγος της μη ανίχνευσης έγκειται στο ότι το κακόβουλο λογισμικό διανεμήθηκε μέσω νόμιμα υπογεγραμμένων ενημερώσεων λογισμικού (Orion updates), τις οποίες τα συστήματα ασφαλείας εμπιστεύθηκαν πλήρως. Η τεχνική αυτή θυμίζει τη στρατηγική του Δούρειου Ίππου, όπως περιγράφεται στην αρχαία ελληνική παράδοση: κατά τον Τρωικό Πόλεμο, οι Αχαιοί εισήγαγαν στρατιώτες εντός των τειχών της Τροίας μέσω ενός φαινομενικά αθώου δώρου. Κατ' αντιστοιχία, ο SUNBURST ενσωματώθηκε σε φαινομενικά αξιόπιστες ενημερώσεις του Orion, τις οποίες οι πελάτες εγκατέστησαν εν αγνοία τους. Πρόκειται για μια σιωπηλή και μεθοδική διείσδυση, χωρίς ειδοποιήσεις και χωρίς διακοπές λειτουργίας.

Οι τεχνικές αποφυγής ήταν εξαιρετικά εξελιγμένες: αδράνεια μετά την εγκατάσταση, μεταμφίηση δικτυακής κίνησης, χρήση obfuscated blocklists και αξιοποίηση νόμιμων εργαλείων συστήματος. Οι επιτιθέμενοι ενεργούσαν σαν διαχειριστές δικτύου, ενώ εφάρμοσαν τεχνικές διαγραφής αρχείων καταγραφής (log deletion) και αφαίρεσης backdoors μετά την εξασφάλιση πρόσβασης. Σε οργανωτικό επίπεδο, η έλλειψη παρακολούθησης (monitoring) και ορατότητας (visibility), ιδιαίτερα εντός του περιβάλλοντος ανάπτυξης λογισμικού, σε συνδυασμό με την υπερβολική εμπιστοσύνη σε αξιόπιστους παρόχους, αποτέλεσε κρίσιμη αστοχία.

2. Το Ζήτημα του Κωδικού "solarwinds123"

Όσον αφορά τον αδύναμο κωδικό "solarwinds123", ο οποίος χρησιμοποιούνταν από το 2017 και παρέμεινε δημοσίως εκτεθειμένος σε GitHub για πάνω από ένα έτος, τα στοιχεία παραμένουν αντιφατικά. Ο ερευνητής ασφαλείας Vinoth Kumar απέδειξε ότι παρείχε πρόσβαση σε FTP server με δυνατότητα upload αρχείων, ενώ η Goldin Solutions δήλωσε ότι αφορούσε third-party application ασύνδετη με τα IT συστήματα. Η εταιρεία δεν εξήγησε γιατί η τεχνολογία της επέτρεπε τέτοιους κωδικούς, ούτε γιατί απουσίαζαν βασικά μέτρα όπως MFA ή credential rotation. Αντί για αυτοκριτική, επέλεξε να εκτρέψει αρχικά τις ευθύνες σε intern, αφήγημα που η κοινότητα κυβερνοασφάλειας καταδίκασε ομόφωνα. Ανεξαρτήτως του εάν ο κωδικός αποτέλεσε πράγματι attack vector, η

ύπαρξή του αποκαλύπτει σοβαρές ελλείψεις στην κουλτούρα ασφαλείας ενός οργανισμού στον οποίο εκατοντάδες φορείς εμπιστεύονταν τις κρίσιμες υποδομές τους.

3. Προτεινόμενα Μέτρα Ασφάλειας και Συμπεράσματα

Η ανάλυση καταδεικνύει ότι υπήρχαν τόσο ευκαιρίες αποτροπής όσο και μηχανισμοί έγκαιρης ανακάλυψης. Σε τεχνικό επίπεδο, η παρακολούθηση outbound HTTP PUT/POST requests, η επιθεώρηση Scheduled Task modifications, η παρακολούθηση PowerShell events (Event ID 400), ο έλεγχος NTFS timestamps, η ανάλυση logon activity για σχέσεις one-to-many, και ο γεωγραφικός εντοπισμός IP για ανίχνευση impossible travel, αποτελούσαν εφικτούς μηχανισμούς που η FireEye/Mandiant εντόπισε εκ των υστέρων. Σε οργανωτικό επίπεδο, η υιοθέτηση proactive detection, η εφαρμογή threat hunting, η αξιοποίηση SIEM, η παρακολούθηση Active Directory και η εφαρμογή DLP (Data Loss Prevention) θα είχαν περιορίσει σημαντικά την παραβίαση. Η SolarWinds αναγνώρισε ότι η αναβάθμιση σε έκδοση 2020.2.5, η ανάκληση πιστοποιητικών υπογραφής κώδικα, η εγκατάσταση πίσω από firewalls και ο περιορισμός συνδέσεων αποτελούσαν αναγκαία μέτρα, υιοθετώντας προσέγγιση "Secure by Design". Επιπλέον, ο ENISA προτείνει δομικά μέτρα όπως Zero Trust Architecture, supply chain risk management, continuous monitoring, MFA και threat intelligence sharing.

Ωστόσο, πέραν των τεχνικών μέτρων, το περιστατικό αποτελεί πρωτίστως υπενθύμιση της ευπάθειας που ενυπάρχει στις σύγχρονες εφοδιαστικές αλυσίδες λογισμικού. Όπως χαρακτηριστικά επεσήμανε ο πρώην διευθυντής CIA και NSA Michael Hayden, οι απειλές εφοδιαστικής αλυσίδας δεν αποτελούν πρόβλημα που μπορεί να λυθεί οριστικά. Η παραβίαση ενός μόνο αξιόπιστου παρόχου αρκεί για να εκθέσει χιλιάδες οργανισμούς, και ακόμα κι αν ένας οργανισμός εφαρμόζει τα υψηλότερα πρότυπα ασφαλείας, παραμένει τόσο ασφαλής όσο ο πιο αδύναμος κρίκος της αλυσίδας του.

Παρά την επίσημη απόδοση της επίθεσης στην APT29 (κοινή ανακοίνωση FBI/CISA/NSA/ODNI, Απρίλιος 2021), δεν ασκήθηκαν ποινικές διώξεις, η Ρωσία αρνήθηκε κάθε εμπλοκή, και η ίδια η SolarWinds δήλωσε ότι δεν επαλήθευσε ανεξάρτητα την ταυτότητα των δραστών. Η αβεβαιότητα αυτή υπογραμμίζει ότι η απόδοση ευθυνών σε κυβερνοεπιθέσεις παραμένει εξαιρετικά δυσχερής. Σαφώς, δεν μπορεί κανείς να αποκλείσει ότι η παραβίαση διευκολύνθηκε από εσωτερικές αδυναμίες, υπάλληλο που δεν ανέφερε ύποπτη δραστηριότητα φοβούμενος τις συνέπειες, ελλιπείς ελέγχους, ή αδυναμίες γνωστές αλλά μη αντιμετωπισμένες εγκαίρως.

Το ουσιαστικό δίδαγμα, επομένως, δεν αφορά τόσο τον δράστη, αλλά τον τρόπο που η βιομηχανία διαχειρίζεται τη στάση ασφαλείας της εξαρχής. Η παραβίαση της SolarWinds δεν ήταν αποτυχία μόνο μιας εταιρείας, αλλά συστημική αποτυχία στον τρόπο με τον οποίο οργανισμοί σχεδιάζουν, διανέμουν και εμπιστεύονται ψηφιακά προϊόντα. Το περιστατικό οδήγησε σε ρυθμιστικές αλλαγές, όπως το Executive Order 14028 (Μάιος 2021) και στη δημιουργία εκτενούς βιβλιογραφίας και ανάπτυξης πλαισίων ασφαλείας, με στόχο την

θωράκιση έναντι μελλοντικών supply chain attacks. Ωστόσο, η πρόσφατη παραβίαση της πλατφόρμας europa.eu (Μάρτιος 2026) μέσω supply chain compromise του εργαλείου Trivy, η οποία εξέθεσε δεδομένα τουλάχιστον 30 ευρωπαϊκών φορέων, επιβεβαιώνει ότι η απειλή παραμένει ενεργή και διαρκώς εξελισσόμενη. Συνοψίζοντας, η αποτελεσματική αντιμετώπισή τους προϋποθέτει θεμελιώδη αναθεώρηση της έννοιας της εμπιστοσύνης: από ένα μοντέλο σιωπηρής αποδοχής σε ένα μοντέλο συνεχούς επαλήθευσης, διαφάνειας και συλλογικής ευθύνης, όπου κάθε κρίκος της αλυσίδας αντιμετωπίζεται ως δυνητικό σημείο επίθεσης.

ΒΙΒΛΙΟΓΡΑΦΙΑ

1. *Solarwinds Security Advisory* (no date) *SolarWinds*. Available at: <https://www.solarwinds.com/sa-overview/securityadvisory#about-supernova> (Accessed: 24 March 2026).
2. *Solarwinds Supply Chain attack uses Sunburst Backdoor* | *Google Cloud Blog* (no date) *Google*. Available at: <https://cloud.google.com/blog/topics/threat-intelligence/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor> (Accessed: 24 March 2026).
3. (No date) *Solarwinds Supply Chain Attack: Indicators of compromise (iocs)*. Available at: https://www.guidepointsecurity.com/wp-content/uploads/2020/12/SolarWinds-Supply-Chain-Attack_-IOCs_01082021.pdf (Accessed: 24 March 2026).
4. Rapid7 (no date) *Solarwinds supply-chain attack: Sunspot explained: Rapid7 blog*, *Rapid7*. Available at: <https://www.rapid7.com/blog/post/2021/01/12/update-on-solarwinds-supply-chain-attack-sunspot-and-new-malware-family-associations/> (Accessed: 24 March 2026).
5. Alkhadra, R., Abuzaid, J. and AlShammari, M. (2021) *Solar winds hack: In-depth analysis and countermeasures* | *IEEE conference publication* | *IEEE Xplore*. Available at: <https://ieeexplore.ieee.org/abstract/document/9579611> (Accessed: 24 March 2026).
6. Huddleston, J. *et al.* (2021) *How vmware exploits contributed to Solarwinds Supply-Chain attack* | *IEEE conference publication* | *IEEE xplore*. Available at: <https://ieeexplore.ieee.org/document/9799263/> (Accessed: 24 March 2026).
7. (No date) *Remediating networks affected by the Solarwinds and active directory/M365 compromise* | *cisa*. Available at:

- <https://www.cisa.gov/news-events/news/remediating-networks-affected-solarwinds-and-active-directorym365-compromise>
(Accessed: 24 March 2026).
8. The Hacker News (2021) *Solarwinds blames intern for 'solarwinds123' password lapse*, *The Hacker News*. Available at:
<https://thehackernews.com/2021/03/solarwinds-blame-intern-for-weak.html>
(Accessed: 24 March 2026).
 9. *A not so secret password: Solarwinds123* (no date) *SA-SG Lockup - White*. Available at: <https://www.sessionguardian.com/blog/a-not-so-secret-password-solarwinds123> (Accessed: 24 March 2026).
 10. *FAQ: Security advisory* (no date) *SolarWinds*. Available at:
<https://www.solarwinds.com/sa-overview/securityadvisory/faq>
(Accessed: 24 March 2026).
 11. *Solarwinds Supply Chain attack uses Sunburst Backdoor* | *Google Cloud Blog* (no date a) *Google*. Available at:
<https://cloud.google.com/blog/topics/threat-intelligence/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor>
(Accessed: 24 March 2026).
 12. Fung, B. and Sands, G. (2021) *Former SolarWinds CEO blames intern for 'solarwinds123' password leak* | *CNN politics*, *CNN*. Available at:
<https://www.cnn.com/2021/02/26/politics/solarwinds123-password-intern>
(Accessed: 24 March 2026).
 13. Wolff, J. (2021) *The former SolarWinds CEO is blaming the firm's poor cybersecurity on an intern*, *Slate Magazine*. Available at:
<https://slate.com/technology/2021/03/solarwinds-hack-cyber-espionage-intern-password.html>
(Accessed: 24 March 2026).
 14. (No date) *SolarWinds CEO expresses regret for 'blame the intern' defense during Orion Hack Investigation* | *SC media*. Available at:
<https://www.scworld.com/news/solarwinds-ceo-expresses-regret-for-blame-the-intern-defense-during-orion-hack>
(Accessed: 24 March 2026).
 15. The Hacker News (2021) *Solarwinds blames intern for 'solarwinds123' password lapse*, *The Hacker News*. Available at: <https://thehackernews.com/2021/03/solarwinds-blame-intern-for-weak.html>
(Accessed: 24 March 2026).
 16. (No date a) *Advanced persistent threat compromise of government agencies, critical infrastructure, and private sector organizations* | *CISA*. Available at:
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a>
(Accessed: 24 March 2026).
 17. (No date a) *Ed 21-01: Mitigate solarwinds orion code compromise (closed)* | *cisa*. Available at: <https://www.cisa.gov/news-events/directives/ed-21-01->

- [mitigate-solarwinds-orion-code-compromise-closed](#) (Accessed: 24 March 2026).
18. (No date a) *Remediating networks affected by the Solarwinds and active directory/M365 compromise* | cisa.
Available at: <https://www.cisa.gov/news-events/news/remediating-networks-affected-solarwinds-and-active-directorym365-compromise>
(Accessed: 24 March 2026).
 19. *Executive order on improving the nation's cybersecurity* | The White House (no date) National Archives and Records Administration.
Available at:

<https://bidenwhitehouse.archives.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity/>
(Accessed: 24 March 2026).
 20. Dinu, C. (2021) *Solarwinds attack cost impacted companies an average of \$12 million*, Heimdal Security Blog.
Available at: <https://heimdalsecurity.com/blog/solarwinds-attack-cost-impacted-companies-an-average-of-12-million/>
(Accessed: 24 March 2026).
 21. Evgeny (2022) *Solarwinds attack: Complete Analysis, timeline, impact, and the shift to Zero trust*, TerraZone. Available at: <https://terrazone.io/solarwinds-attack/>
(Accessed: 24 March 2026).
 22. *Solarwinds Supply Chain attack* (no date) Fortinet. Available at:
<https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack>
(Accessed: 24 March 2026).
 23. APT29 (no date) APT29, IRON RITUAL, IRON HEMLOCK, NobleBaron, Dark Halo, NOBELIUM, UNC2452, YTTIRIUM, The Dukes, Cozy Bear, CozyDuke, SolarStorm, Blue Kitsune, UNC3524, Midnight Blizzard, Group G0016 | MITRE ATT&CK®. Available at:
<https://attack.mitre.org/groups/G0016/> (Accessed: 24 March 2026)
 24. *What is a supply chain attack?* (no date) CrowdStrike. Available at:
<https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/supply-chain-attack/> (Accessed: 24 March 2026).
 25. (No date a) *The Solarwinds cyberattack*.
Available at: <https://www.rpc.senate.gov/policy-papers/the-solarwinds-cyberattack> (Accessed: 24 March 2026).
 26. Cert-Eu (no date a) *European Commission Cloud Breach: A supply-chain compromise*, CERT. Available at: <https://cert.europa.eu/blog/european-commission-cloud-breach-trivy-supply-chain> (Accessed: 03 April 2026).